SOC Level 3 Report

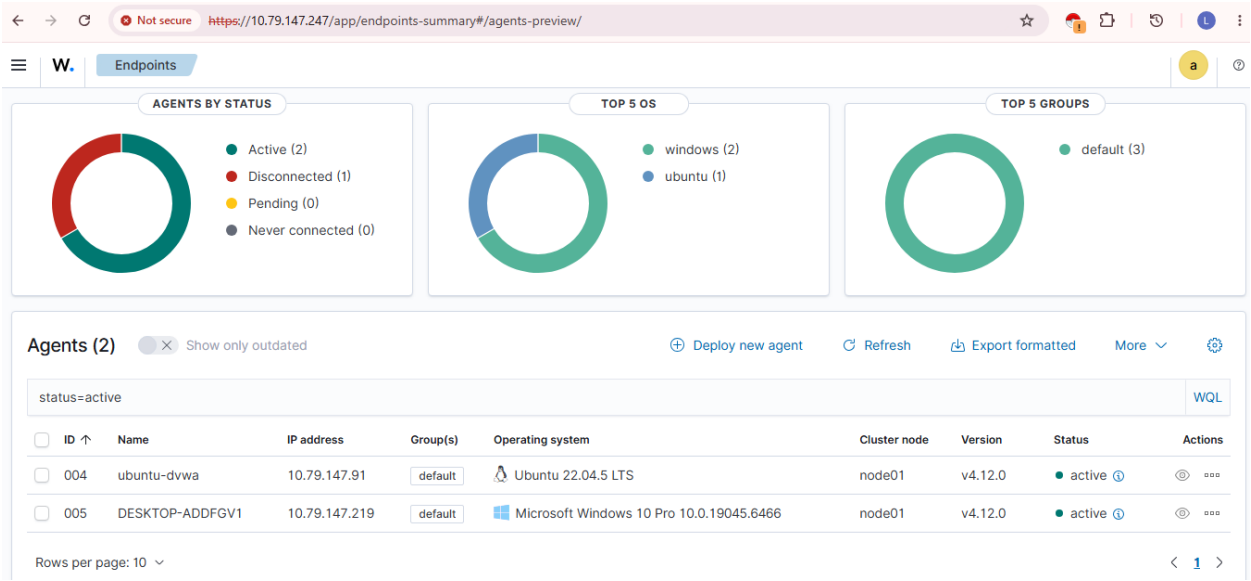
Analyst: Loveth Adebayo
Date: October 25, 2026
Environment: Wazuh SIEM Manager (Ubuntu), Ubuntu Web Server, Windows 10 Endpoint

1. Executive Summary

The organization successfully detected and contained a simulated Advanced Persistent Threat (APT) campaign orchestrated by the fictional hacktivist group Crimson Dawn. The attack targeted our public-facing Web Server, established persistence, attempted lateral movement to a Windows workstation, and tried to exfiltrate sensitive intellectual property. Using the Wazuh SIEM, our SOC team identified the reconnaissance, tracked the persistence mechanisms, caught the lateral movement attempt, and detected the data staging. Finally, a custom Threat Intelligence rule was deployed to block and alert on outbound Command & Control (C2) traffic. The incident was fully contained without real data loss.

2. Incident Background and Affected Systems

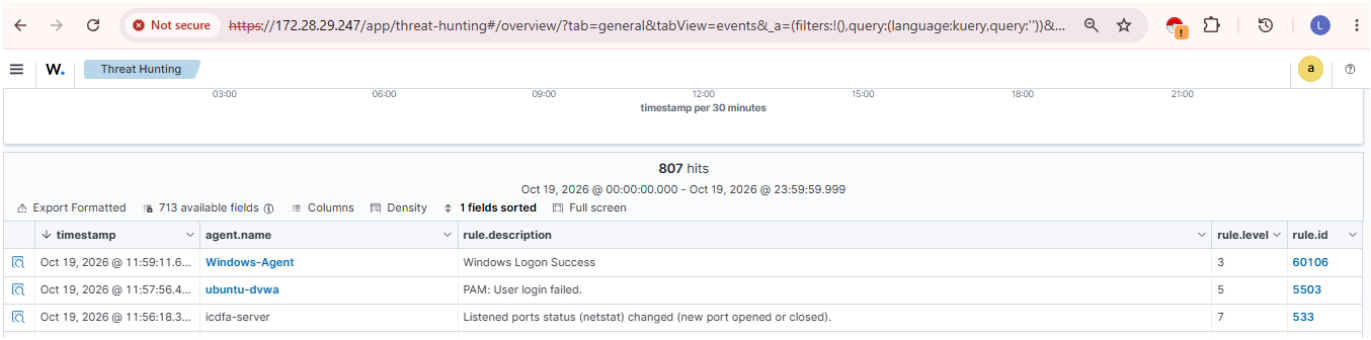
Crimson Dawn's objective was to steal sensitive intellectual property and publicly disclose it to damage the company's reputation. The attack spanned two primary systems:
Web Server (ubuntu-dvwa): External-facing Ubuntu server, initially compromised.
Windows Endpoint (DESKTOP-ADDFGV1): Internal workstation targeted for data theft.



Phase1_Web_Server_Agent_Active

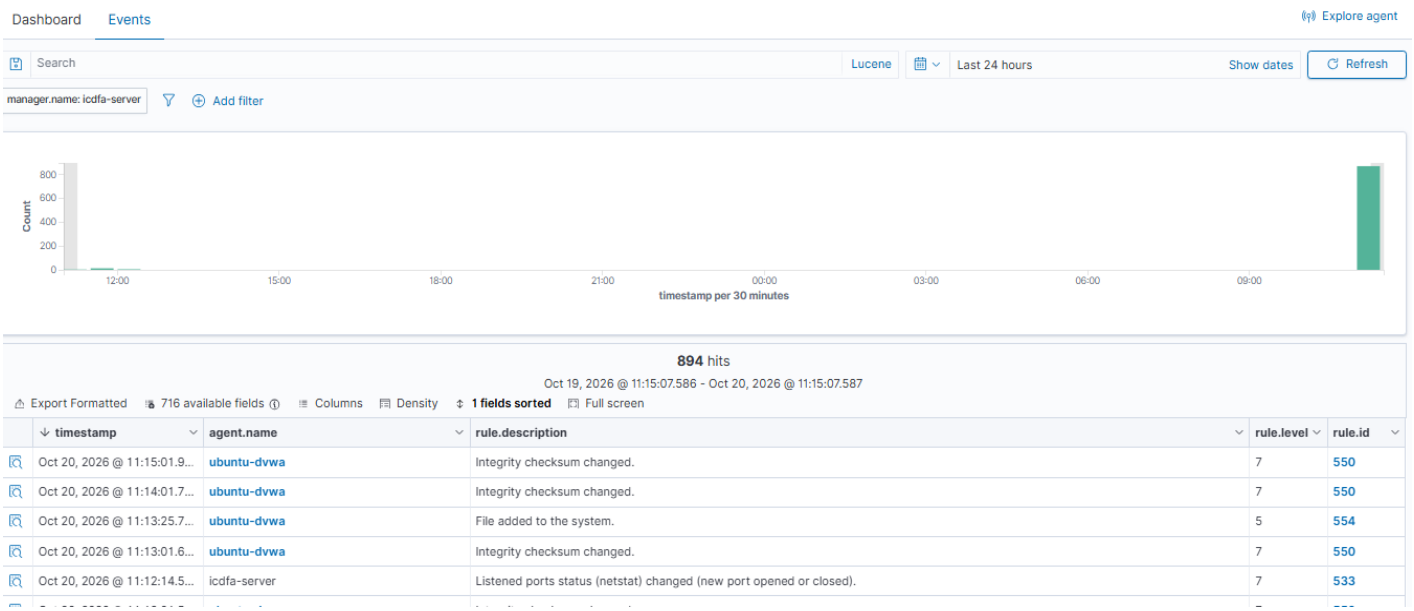
3. Attack Narrative and Cyber Kill Chain Analysis

Phase 1: Reconnaissance (Cyber Kill Chain: Reconnaissance)
The attacker performed port scanning and SSH brute-force attempts against the Web Server. Wazuh detected these as authentication_failed events.
MITRE ATT&CK: T1595 (Active Scanning), T1110 (Brute Force).



Phase1_Failed_Login_Alerts

Phase 2: Weaponization and Exploitation (Cyber Kill Chain: Installation)
The attacker exploited the Web Server and dropped a disguised backdoor payload (update.pdf.exe) in the /tmp directory. To maintain persistence, they created a cron job (hidden-log) designed to beacon out every minute.
MITRE ATT&CK: T1053.003 (Scheduled Task/Job: Cron), T1036 (Masquerading).



Phase2_FIM_Payload

919 hits

Oct 19, 2026 @ 11:27:36.560 - Oct 20, 2026 @ 11:27:36.561

Export Formatted | 716 available fields | Columns | Density | 1 fields sorted | Full screen

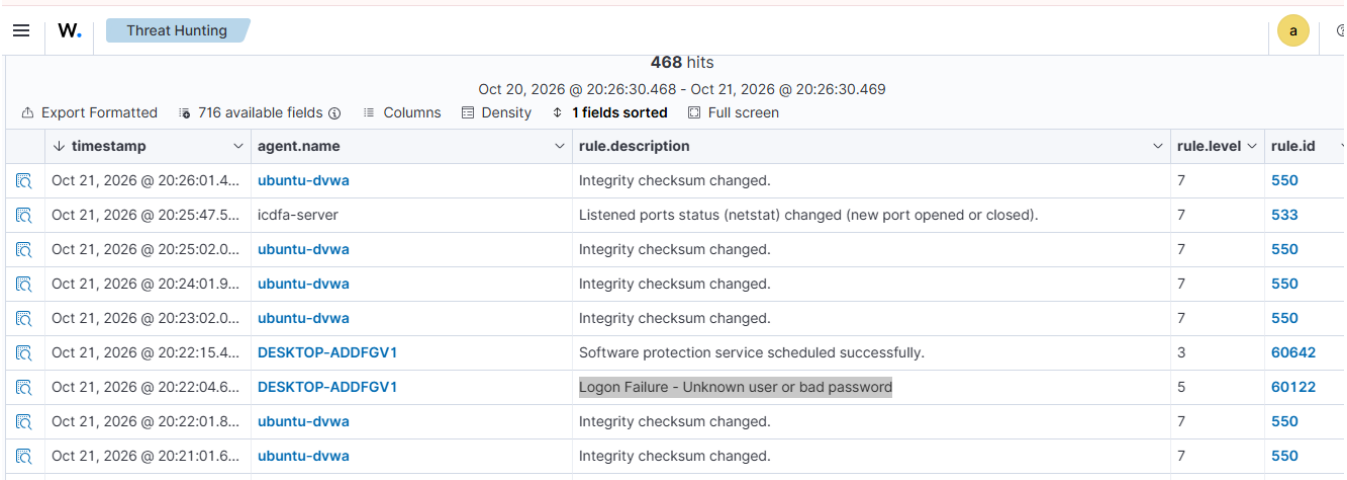
timestamp	agent.name	rule.description	rule.level	rule.id
Oct 20, 2026 @ 11:27:18.8...	Windows-Agent	Windows Logon Success	3	60106
Oct 20, 2026 @ 11:27:16.7...	Windows-Agent	Windows Logon Success	3	60106
Oct 20, 2026 @ 11:27:01.0...	ubuntu-dvwa	Integrity checksum changed.	7	550
Oct 20, 2026 @ 11:26:02.0...	ubuntu-dvwa	Integrity checksum changed.	7	550
Oct 20, 2026 @ 11:25:01.8...	ubuntu-dvwa	Integrity checksum changed.	7	550
Oct 20, 2026 @ 11:24:23.6...	Windows-Agent	Windows Logon Success	3	60106
Oct 20, 2026 @ 11:24:01.8...	ubuntu-dvwa	Integrity checksum changed.	7	550
Oct 20, 2026 @ 11:23:01.7...	ubuntu-dvwa	Integrity checksum changed.	7	550
Oct 20, 2026 @ 11:22:01.6...	ubuntu-dvwa	Integrity checksum changed.	7	550
Oct 20, 2026 @ 11:21:53.5...	ubuntu-dvwa	Crontab entry changed.	5	2832
Oct 20, 2026 @ 11:21:52.4...	ubuntu-dvwa	File deleted.	7	553
Oct 20, 2026 @ 11:21:50.1...	ubuntu-dvwa	Integrity checksum changed.	7	550

Phase2_Cron_Persistence

```
dvwa@ubuntu-dvwa:~$ crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
* * * * * echo 'C2 Check-in' >> /tmp/.hidden-log
dvwa@ubuntu-dvwa:~$
```

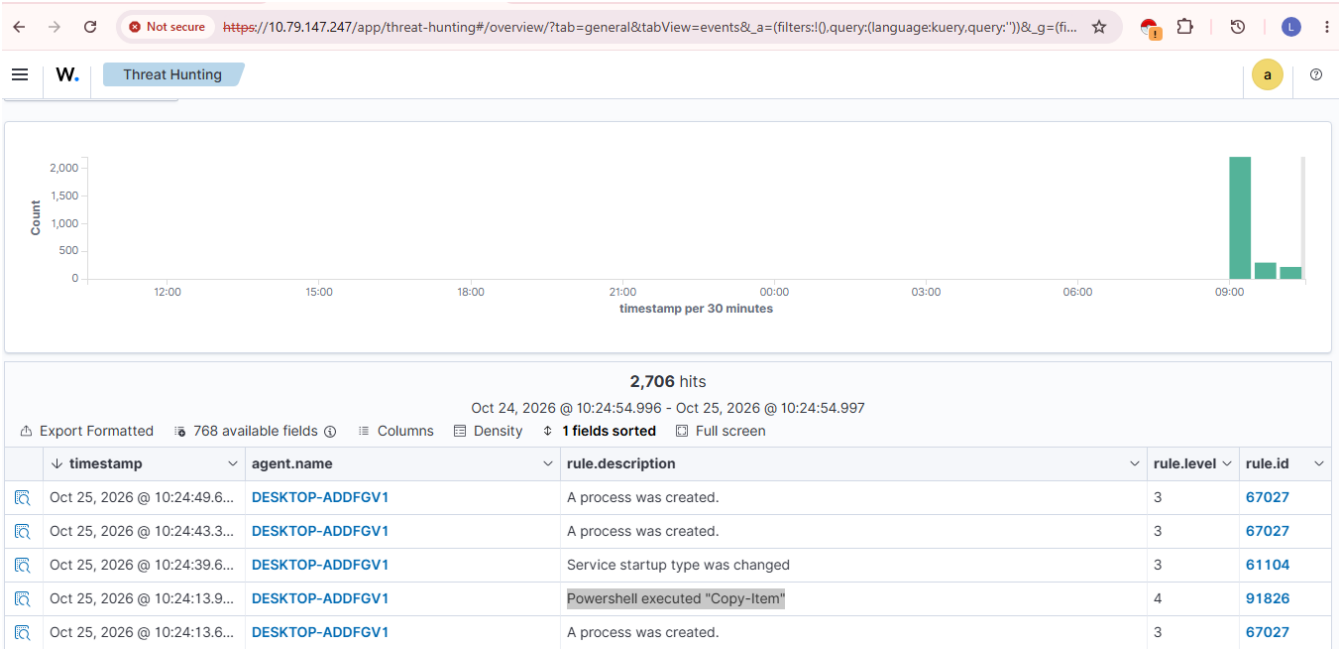
Phase2_Cron_Job_Verified

Phase 3: Lateral Movement (Cyber Kill Chain: Actions on Objectives)
The attacker attempted to move from the Web Server to the Windows endpoint by targeting the Windows ADMIN$ share. This generated a failed authentication attempt on the Windows machine.
MITRE ATT&CK: T1021.002 (Remote Services: SMB/Windows Admin Shares).



Phase3_Lateral_Movement_Events

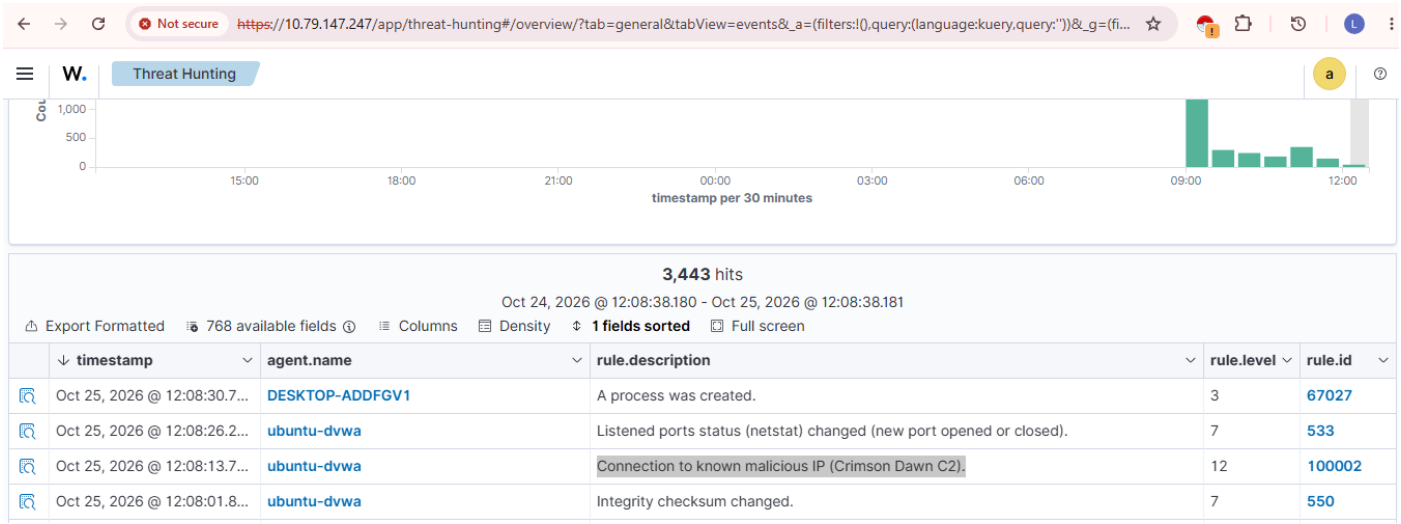
Phase 4: Data Exfiltration (Cyber Kill Chain: Exfiltration)
The attacker compressed sensitive files into staged_data.zip and executed a PowerShell command (Copy-Item) to exfiltrate the archive to a C2 server (10.79.147.91).
MITRE ATT&CK: T1560.001 (Archive Collected Data), T1041 (Exfiltration Over C2 Channel).



Phase4_Data_Exfiltration

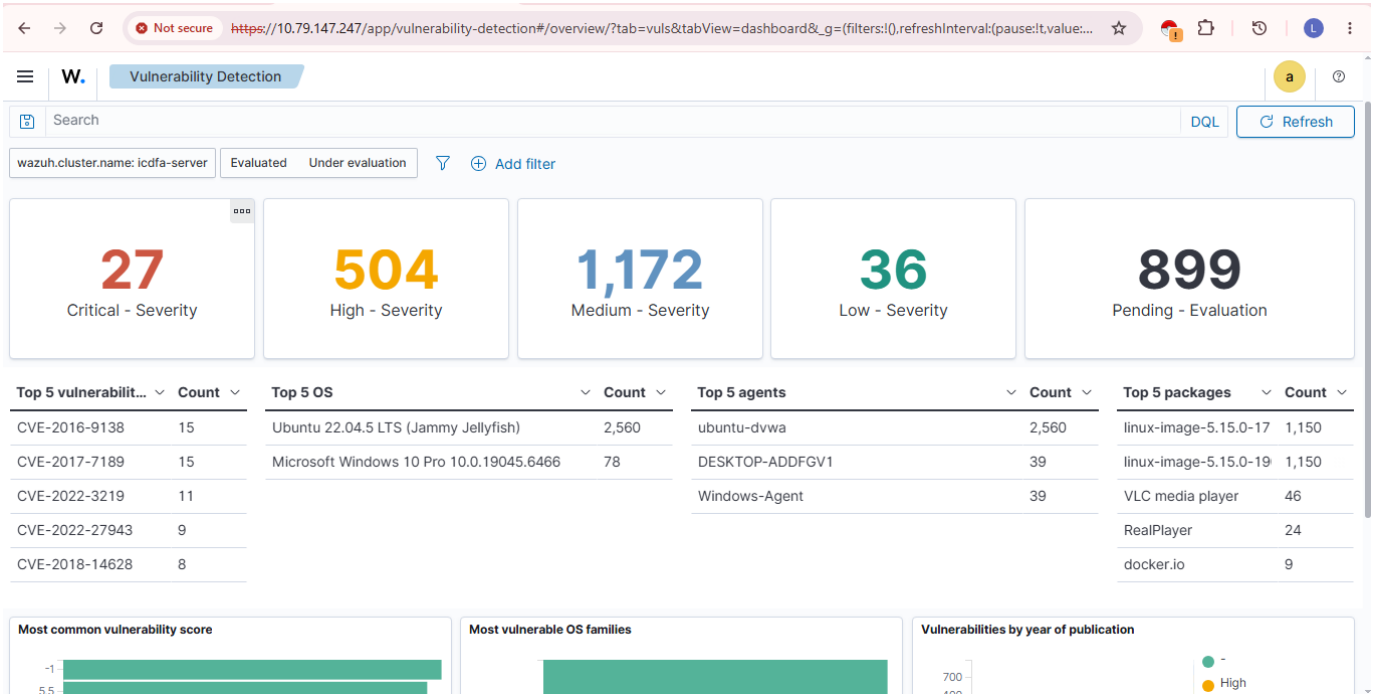
4. Technical Investigation Findings
Indicators of Compromise (IOCs)
C2 IP Address: 10.79.147.91
Malicious Artifacts: /tmp/update.pdf.exe, C:\Users\loveth adebayo\SensitiveFiles\payload.exe, staged_data.zip
Persistence Command: echo 'C2 Check-in' >> /tmp/.hidden-log

Custom Detection Rule (Strategic Countermeasure)
To defend against this specific C2 IP, a custom Wazuh rule (Rule ID: 100002) was written and deployed to the Manager. The rule triggers a Level 12 critical alert whenever traffic to 10.79.147.91 is detected. This rule was validated and successfully generated live alerts on the dashboard.



Phase5_Custom_Rule_Validation

Vulnerability Detection
Wazuh Vulnerability Detection scanned the Web Server and identified 27 Critical and 504 High severity CVEs (Common Vulnerabilities and Exposures). The top vulnerabilities likely provided the initial attack surface used by Crimson Dawn to breach the server.



Phase5_Vulnerability_Detection

5. Business Impact Assessment
If this had been a real attack, the exfiltration of the SensitiveFiles directory would have resulted in the loss of intellectual property. The reputational damage of Crimson Dawn publicly leaking this data, combined with potential regulatory fines for failing to protect sensitive information, would have caused severe financial and operational impact.

6. Root Cause Analysis
Unpatched External Server: The Web Server had dozens of critical vulnerabilities that were left unpatched, allowing the initial breach.
Lack of Network Segmentation: The Web Server was allowed to communicate directly with internal endpoints over SMB, enabling lateral movement.
No Automated Endpoint Blocking: The Windows endpoint allowed multiple failed logons and the execution of suspicious PowerShell commands without locking the user out.

7. Strategic Security Recommendations (Prioritized)
1. Enforce Network Segmentation: Isolate the Web Server (DMZ) from internal endpoints. The Web Server should never be able to reach a Windows workstation's ADMIN$ share.
2. Automated Threat Intelligence Integration: Integrate Wazuh with threat feeds to automatically block known malicious IPs and domains at the firewall.
3. Deploy an EDR Solution: Implement Endpoint Detection and Response (EDR) to automatically quarantine suspicious files like update.pdf.exe and stop PowerShell from downloading payloads.
4. Patch Management Program: Establish a strict SLA for patching critical and high vulnerabilities identified by the Wazuh Vulnerability Detector.

8. Answers to Strategic Analysis Questions
Q1: What other technique could the attackers use for persistence if they had admin rights?
If they had administrative access to the Windows machine, they could use T1053.005 (Scheduled Task/Job). They could create a Windows Scheduled Task that runs a malicious script on system startup. Defenders can detect this by monitoring Windows Event ID 4698 (A scheduled task was created) or monitoring the C:\Windows\System32\Tasks directory.

Q2: How could Wazuh Vulnerability Detection prevent the initial breach?
Proactive vulnerability management would have flagged the outdated software on the Web Server. By reviewing the Vulnerability Detector dashboard weekly, IT teams could patch the system before an attacker like Crimson Dawn discovers and exploits those CVEs, effectively closing the front door.

Q3: If the C2 IP is blocked, how could the attacker bypass this, and how would Wazuh detect it?
The attacker could bypass a static IP block by using a Domain Name (DNS) instead of a raw IP address. They can simply change the DNS A-record to point to a new IP. Wazuh can detect this by monitoring DNS queries (Sysmon Event ID 22) and using threat intelligence feeds to block malicious domains rather than just IPs.

Q4: Business Justification for Network Segmentation.
Investing in network segmentation is highly cost-effective because it drastically reduces the blast radius of a breach. If an external web server is compromised, segmentation ensures the attacker cannot pivot to internal databases or employee workstations, preventing catastrophic data theft and protecting the company's reputation.